

Politique de Conformité RGPD — CYNA Platform

Version : 1.0

Date : 25 juin 2026

Responsable : Projet Fil Rouge — INGETIS Paris

Plateforme : CYNA — SaaS Cybersécurité

Table des matières

1. Périmètre et définitions

2. Responsable de traitement et sous-traitants

3. Données personnelles collectées

4. Base légale des traitements

5. Finalités des traitements

6. Durée de conservation

7. Droits des utilisateurs

8. Sécurité des données

9. Gestion des incidents de sécurité

10. Cookies et traceurs

11. Transferts de données hors UE

12. Registre des traitements

13. Contact et DPO

1. Périmètre et définitions

1.1 Périmètre

Cette politique s’applique à l’ensemble de la plateforme CYNA, incluant :

- L’API Go (backend REST — port 8080)
- Le serveur web Node.js (site public + interface d’administration — port 3000)
- L’application mobile React Native / Expo (Android & iOS)
- La base de données PostgreSQL
- Les services tiers intégrés (Stripe, Resend)

1.2 Définitions

Terme	Définition
Donnée personnelle	Toute information se rapportant à une personne physique identifiée ou identifiable
Traitement	Toute opération portant sur des données personnelles (collecte, stockage, modification, consultation, effacement)
Responsable de traitement	L’entité qui détermine les finalités et les moyens du traitement
Sous-traitant	L’entité qui traite des données pour le compte du responsable de traitement
Personne concernée	L’utilisateur dont les données personnelles sont traitées
RGPD	Règlement Général sur la Protection des Données (UE) 2016/679

2. Responsable de traitement et sous-traitants

2.1 Responsable de traitement

Projet Fil Rouge — INGEIIS Paris

Contact : cf. [section 13](#)

2.2 Sous-traitants

Sous-traitant	Service	Données transmises	Garanties RGPD
Stripe Inc.	Païement en ligne	Numéro de carte tokenisé (jamais en clair), montant, devise, email	Certifié PCI-DSS, clauses contractuelles types (SCC)
Resend Inc.	Envoi d’emails transactionnels	Email, prénom, type de notification	DPA signé, hébergement USA (SCC)
Expo (Expo Go)	Serveur de développement mobile (optionnel)	URL de l’API (aucune donnée personnelle)	— (aucune donnée personnelle transmise)

Note importante : Stripe est utilisé en mode *tokenization côté client*. Les données bancaires sont tokenisées depuis l’application/l’appareil de l’utilisateur et ne transitent jamais en clair sur les serveurs CYNA.

3. Données personnelles collectées

3.1 Données fournies par l’utilisateur

Catégorie	Données	Source
Identité	Nom, prénom	Formulaire d’inscription / profil
Coordonnées	Email, téléphone	Formulaire d’inscription / profil
Authentification	Mot de passe (hashé bcrypt), secret TOTP (2FA)	Formulaire d’inscription / paramètres de sécurité
Société	Nom, secteur, taille, pays de l’entreprise	Profil utilisateur / entreprise
Païement	Nom sur la carte (tokenisé via Stripe)	Tunnel de paiement
Support	Sujet et message du ticket	Formulaire de contact / support
Newsletter	Email, statut d’abonnement	Formulaire d’inscription newsletter

3.2 Données collectées automatiquement

Catégorie	Données	Source
Navigation	Pages consultées, actions effectuées	Logs API (middleware RequestLogger)
Technique	Adresse IP, user-agent, méthode HTTP, chemin	Logs API (middleware RequestLogger)
Session	Token de session, date d’expiration	Session utilisateur
Utilisation	Dernière connexion, tentatives de connexion échouées	Table utilisateur

3.3 Données non collectées

CYNA ne collecte pas les catégories suivantes :

- ☐ Données bancaires en clair (tokenisées via Stripe)
- ☐ Données biométriques (hors WebAuthn — stockage local facultatif)
- ☐ Données de localisation GPS
- ☐ Contacts de l'appareil
- ☐ Photos / médias personnels (hors téléversement admin)

4. Base légale des traitements

Traitement	Base légale (art. 6 RGPD)
Création et gestion du compte	Exécution contractuelle (art. 6.1.b)
Traitement des commandes et paiements	Exécution contractuelle (art. 6.1.b)
Envoi d’emails transactionnels	Exécution contractuelle (art. 6.1.b)
Gestion du support client	Exécution contractuelle (art. 6.1.b)
Facturation et comptabilité	Obligation légale (art. 6.1.c)
Sécurité et prévention des fraudes	Intérêt légitime (art. 6.1.f)
Journalisation des accès (logs)	Intérêt légitime (art. 6.1.f)
Newsletter marketing	Consentement (art. 6.1.a)
Cookies fonctionnels	Intérêt légitime (art. 6.1.f)

5. Finalités des traitements

Finalité	Données concernées	Durée
Fourniture du service (authentification, catalogue, commandes)	Identité, coordonnées, société	Compte actif
Paiement et facturation	Nom, email, montant, token Stripe	10 ans (comptabilité)
Support client	Nom, email, messages tickets	3 ans après fermeture
Sécurité (logs, rate limiting, anti-fraude)	IP, user-agent, actions	90 jours (logs)
Newsletter	Email	Jusqu’au désabonnement
Sauvegarde et continuité	Toutes les données	Durée de conservation propre à chaque catégorie

6. Durée de conservation

Données	Durée de conservation	Justification
Compte utilisateur	Pendant la durée d'activité + 1 an après désactivation	Gestion contractuelle
Mot de passe (hashé)	Jusqu'à modification ou suppression du compte	Authentification
Sessions	Durée de validité du token + purge des tokens expirés	Sécurité
Commandes et factures	10 ans	Obligation comptable (CGI art. L123-22)
Tickets support	3 ans après la dernière interaction	Gestion client
Logs API (base de données)	90 jours (purge automatique)	Sécurité — recommandation CNIL
Logs API (fichier JSONL)	Illimitée (stockage fichier)	Audit et conformité
Newsletter	Jusqu'au désabonnement ou inactivité 3 ans	Consentement
Données de paiement (Stripe)	Gérées par Stripe selon leur politique	Sous-traitant
Sauvegardes PostgreSQL	Durée de conservation propre à chaque donnée incluse	Continuité d'activité

Procédure de purge automatique

```
-- Purge des logs > 90 jours (exécutée au démarrage de L'API)
DELETE FROM api_logs WHERE timestamp < NOW() - INTERVAL '90 days';

-- Nettoyage des sessions expirées
DELETE FROM session_utilisateur WHERE date_expiration < NOW();

-- Nettoyage des tokens de vérification expirés
DELETE FROM email_verification_tokens WHERE expires_at < NOW();
```

7. Droits des utilisateurs

Conformément aux articles 15 à 22 du RGPD, chaque utilisateur dispose des droits suivants :

7.1 Droit d'accès (art. 15)

L'utilisateur peut obtenir confirmation que ses données sont traitées et en recevoir une copie.

Implémentation :

- API : GET /api/users/me — profil complet
- Interface admin : consultation des comptes utilisateurs
- Demande étendue : cf. [section 13](#)

7.2 Droit de rectification (art. 16)

L'utilisateur peut modifier ses données personnelles.

Implémentation :

- API : PUT /api/users/me — modification du profil
- Interface mobile : écran account/profile.tsx

7.3 Droit à l'effacement (art. 17)

L'utilisateur peut demander la suppression de son compte et de ses données.

Implémentation :

- API : `DELETE /api/users/me` — suppression du compte
- Effacement en cascade : sessions, tokens API, tickets, notifications, commandes anonymisées

7.4 Droit à la limitation du traitement (art. 18)

L'utilisateur peut demander le gel temporaire du traitement de ses données en cas de contestation.

7.5 Droit à la portabilité (art. 20)

L'utilisateur peut recevoir ses données dans un format structuré (JSON).

Implémentation :

- Export JSON disponible sur demande (cf. [section 13](#))

7.6 Droit d'opposition (art. 21)

L'utilisateur peut s'opposer au traitement de ses données à des fins de marketing direct.

Implémentation :

- Newsletter : lien de désabonnement dans chaque email
- API : `POST /api/newsletter/unsubscribe`

7.7 Droit de ne pas faire l'objet d'une décision automatisée (art. 22)

CYNA n'utilise pas de prise de décision automatisée ayant un effet juridique sur les utilisateurs.

Procédure d'exercice des droits

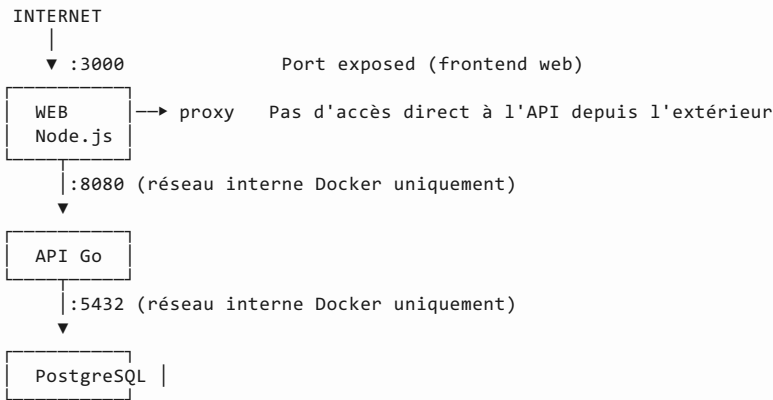
1. L'utilisateur envoie sa demande par email (cf. [section 13](#))
 2. CYNA accuse réception sous **72 heures**
 3. CYNA traite la demande sous **1 mois** (prolongeable à 2 mois pour les demandes complexes)
 4. La réponse est fournie gratuitement (sauf demandes abusives, art. 12.5)
-

8. Sécurité des données

8.1 Mesures techniques

Mesure	Description
Chiffrement des mots de passe	bcrypt (hash + sel)
Authentification forte (2FA)	TOTP (Time-based One-Time Password)
WebAuthn	Support optionnel de la biométrie / clé de sécurité (FIDO2)
Rate limiting	Multi-couche (API Go + Node.js) : 100 req/min API, 5 req/15min login
Headers de sécurité	CSP, HSTS, X-Content-Type-Options, X-Frame-Options, X-XSS-Protection
Validation des entrées	Middleware de validation (API Go), validation des schémas
Limitation de taille	MaxBodySize middleware (prévention déni de service)
CORS restreint	Origines autorisées limitées aux domaines connus
Journalisation	Logs en triple stockage (RAM + PostgreSQL + fichier JSONL)
Sauvegardes chiffrées	Backup automatique via pg_dump

8.2 Sécurité réseau



- L'API Go (port 8080) n'est pas exposée directement sur Internet en production
- La base de données (port 5432) n'est accessible que depuis le réseau interne Docker
- Communication entre services via réseau Docker interne isolé

8.3 Gestion des accès

- Authentification par token de session pour les utilisateurs
- RBAC (Role-Based Access Control) pour les administrateurs
- Table roles avec permissions granulaires
- API tokens avec permissions limitées (lecture seule / écriture)

8.4 Chiffrement

Donnée	État	Méthode
Mot de passe	Au repos	bcrypt (hash)
Token de session	En transit	TLS (HTTPS recommandé en production)
Paiement	En transit & au repos	Tokenisation Stripe (aucune donnée bancaire stockée côté CYNA)
Sauvegardes	Au repos	Chiffrement via pg_dump sur volume Docker

9. Gestion des incidents de sécurité

9.1 Procédure de notification

Conformément à l'article 33 du RGPD, toute violation de données personnelles doit être notifiée :

1. **Détection** — Identification de l'incident (logs, monitoring, rapport utilisateur)
2. **Confinement** — Mesures immédiates (isolation, blocage, révocation de tokens)
3. **Analyse** — Évaluation de l'impact (nature des données, nombre de personnes concernées)
4. **Notification CNIL** — Sous 72 heures si risque pour les droits et libertés
5. **Notification utilisateurs** — Sans délai injustifié si risque élevé (art. 34)

9.2 Contact incident de sécurité

En cas de suspicion de violation de données :

- **Email** : security@cyna-platform.com (cf. [section 13](#))
- **Délai de réponse** : 24 heures ouvrées

9.3 Registre des violations

Tout incident de sécurité est consigné dans un registre interne comprenant :

- Date et heure de l'incident
- Description des faits
- Données concernées
- Nombre de personnes concernées
- Mesures prises
- Notification CNIL (date, référence)

10. Cookies et traceurs

10.1 Cookies utilisés

Cookie	Type	Finalité	Durée
token_session	Fonctionnel	Authentification	Jusqu'à expiration du token
theme	Fonctionnel	Préférence de thème (clair/sombre)	1 an

10.2 Aucun cookie tiers

CYNA n'utilise pas de cookies publicitaires, de traçage ou de réseaux sociaux.

10.3 Consentement cookies

- Les cookies fonctionnels sont exemptés de consentement préalable (Recommandation CNIL)
- Aucun cookie déposé avant interaction de l'utilisateur
- Les utilisateurs sont informés via la page `legal.tsx` et `cgu.tsx`

11. Transferts de données hors UE

11.1 Sous-traitants hors UE

Sous-traitant	Localisation	Garantie
Stripe Inc.	États-Unis	Clauses contractuelles types (SCC) approuvées par la Commission européenne
Resend Inc.	États-Unis	Clauses contractuelles types (SCC) + DPA signé

11.2 Principe

Les données sont majoritairement hébergées en local (Docker — infrastructure maîtrisée). Seuls les appels aux API Stripe (paiement) et Resend (email) peuvent transférer des données hors UE, dans le cadre des garanties contractuelles mentionnées ci-dessus.

12. Registre des traitements

12.1 Traitement : Gestion des comptes utilisateurs

Champ	Valeur
Finalité	Création, authentification, gestion des comptes
Base légale	Exécution contractuelle (art. 6.1.b)
Données	Email, nom, prénom, téléphone, mot de passe (hashé), TOTP secret
Personnes concernées	Utilisateurs de la plateforme, employés des entreprises clientes
Destinataires	API Go, PostgreSQL, Resend (emails transactionnels)
Durée de conservation	Durée du compte + 1 an

12.2 Traitement : Gestion des paiements et commandes

Champ	Valeur
Finalité	Traitement des commandes, facturation, abonnements
Base légale	Exécution contractuelle (art. 6.1.b), obligation légale (art. 6.1.c)
Données	Nom, email, montant, historique commandes, abonnements
Destinataires	API Go, PostgreSQL, Stripe
Durée de conservation	10 ans (comptabilité)

12.3 Traitement : Journalisation et sécurité

Champ	Valeur
Finalité	Sécurité, détection d'intrusion, audit
Base légale	Intérêt légitime (art. 6.1.f)
Données	IP, user-agent, méthode, chemin, timestamp, statut, durée
Destinataires	API Go, PostgreSQL, fichier JSONL
Durée de conservation	90 jours (base de données), illimitée (fichier)

12.4 Traitement : Newsletter et marketing

Champ	Valeur
Finalité	Envoi de campagnes emailing, communication commerciale
Base légale	Consentement (art. 6.1.a)
Données	Email, statut abonnement
Destinataires	API Go, PostgreSQL, Resend
Durée de conservation	Jusqu'au désabonnement

12.5 Traitement : Support client

Champ	Valeur
Finalité	Traitement des demandes de support, tickets
Base légale	Exécution contractuelle (art. 6.1.b)
Données	Nom, email, message du ticket
Destinataires	API Go, PostgreSQL, Resend (notification)
Durée de conservation	3 ans après fermeture du ticket

13. Contact et DPO

13.1 Contact général

Projet Fil Rouge — INGEIIS Paris

Email : dpo@cyna-platform.com

Adresse : INGETIS Paris — 1 Rue de Stockholm, 75008 Paris, France

13.2 Délégué à la Protection des Données (DPO)

Le DPO peut être contacté pour toute question relative au traitement des données personnelles et à l'exercice des droits mentionnés dans la [section 7](#).

Email : dpo@cyna-platform.com

13.3 Réclamation auprès de la CNIL

Si vous estimez que vos droits ne sont pas respectés, vous pouvez introduire une réclamation auprès de la CNIL :

CNIL

3 Place de Fontenoy, TSA 80715, 75334 Paris Cedex 07

Tél. : +33 (0)1 53 73 22 22

Site : <https://www.cnil.fr>